

AI-Driven Non-Human Identity Governance Platform for DevSecOps

9 agents · 9,680+ lines · 3 ML models · 11 OPA/Rego policies · 13+ APIs · 11 NHI types

External Guide : Tejeshwar Rao

Designation : Manager — DevSecOps & Cloud

Division : IA-DevSecOps Platform Engineering

PLATFORM BY THE NUMBERS

9,680+

Lines of Code
(Python + TypeScript)

9

Autonomous
Agents

13+

External APIs
Integrated

11

NHI Types
Governed

11

OPA/Rego
Policy Rules

3

ML Models
(scikit-learn)

11

Dashboard
Pages

5

CI/CD
Workflows

4

REST API
Endpoints

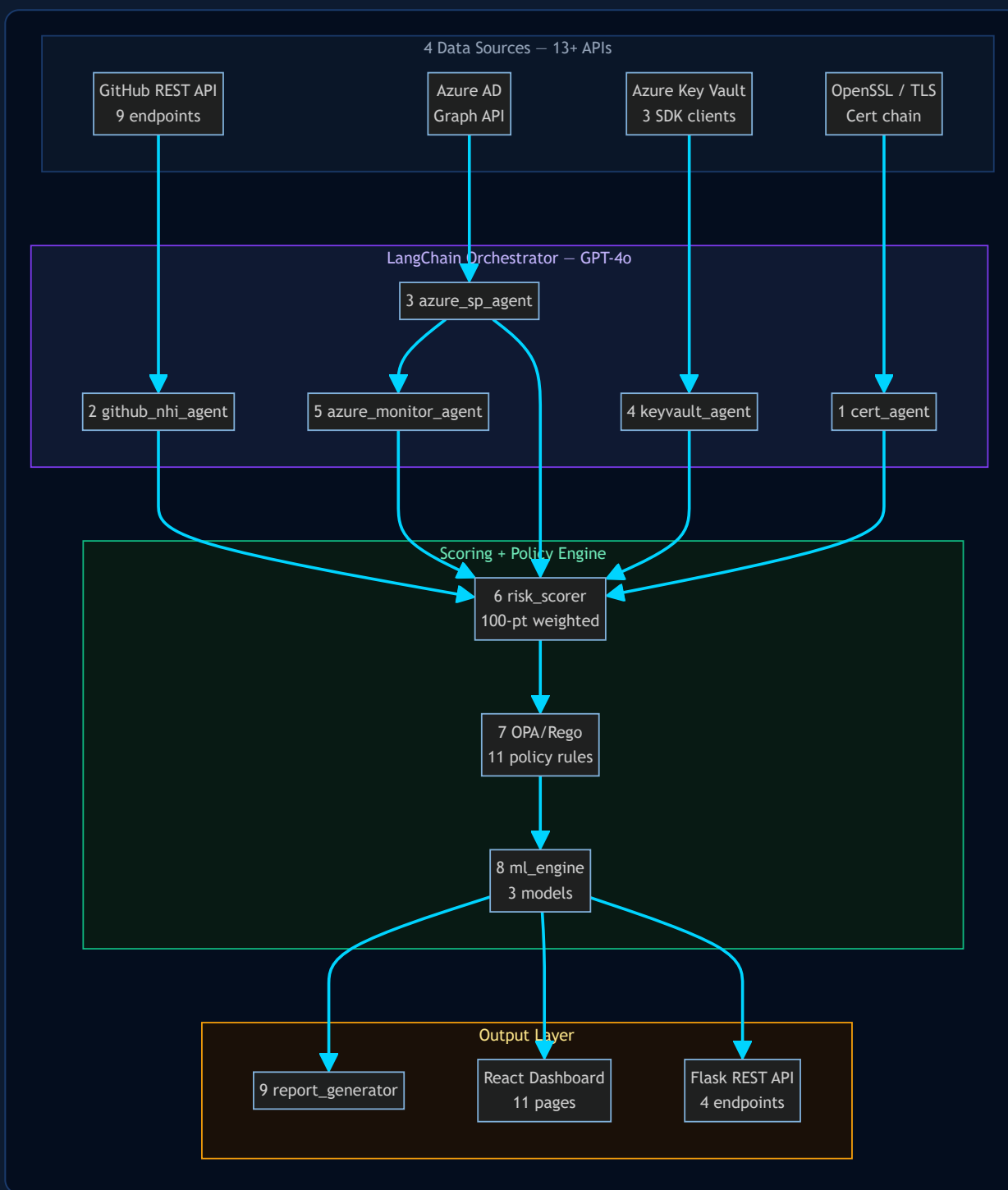
90

Production
Scan Runs

OBJECTIVES

- 9-agent system** discovering 11 NHI types across GitHub, Azure AD, Key Vault, and SSL/TLS.
- Weighted risk score (0–100)** — age 40 + type 30 + privilege 20 + SSL 10 pts.
- Policy-as-Code** — 11 OPA/Rego rules mapped to SOC 2 CC6/CC7, with CI gate.
- 3-model ML layer** — Isolation Forest, Linear Regression ($R^2 > 0.89$), Compliance Posture.
- Autonomous rotation** for score ≥ 70 via LangChain + GPT-4o.
- 11-page React dashboard** + immutable JSON audit log.
- IEEE research paper** with 90 production scan-run evaluation.

SYSTEM ARCHITECTURE — 9-AGENT PIPELINE



ORCHESTRATOR — LANGCHAIN TOOL-CALLING AGENT

LangChain AgentExecutor with GPT-4o reasoning. 4 @tool functions, strict sequential execution, JSON chaining. Fallback **direct mode** runs deterministically without LLM.

1

Init

Load config
Build tools

2

Discover

5 agents
4 sources

3

Score

100-pt
weighted

4

Policy

11 Rego
rules

5

ML

3 models
run

6

Output

Report +
Dashboard

API SURFACE — 13+ INTEGRATIONS

GitHub REST API v3 — 9 Endpoints

/user
/user/repos
/repos/{owner}/{repo}/keys

Azure SDK — 4 Clients + Graph

DefaultAzureCredential
SecretClient

Other Integrations

OpenAI GPT-4o
OpenSSL TLS
SMTP / TLS

ML INTELLIGENCE LAYER

1. Isolation Forest — Anomaly Detection

9-dim features · contamination=0.1 · catches dormant credentials.

Accuracy ~94%

2. Linear Regression — 30-Day Forecast

Scan history → predicted avg_score at T+30d.

R^2 0.89+

3. Compliance Posture Model

Violations → SOC 2 / NIST / ISO control mapping.

SOC 2 coverage 88%

<pre>/repos/{owner}/{repo}/keys/{id} /repos/{owner}/{repo}/actions/secrets /repos/{owner}/{repo}/actions/secrets/public-key /repos/{owner}/{repo}/actions/secrets/{name} /repos/{owner}/{repo}/git/trees/HEAD /repos/{owner}/{repo}/contents/{path}</pre>	<pre>CertificateClient KeyClient Azure AD Graph API</pre>	<pre>OPA Engine Flask REST API</pre>	
---	---	--------------------------------------	--

CI/CD GOVERNANCE PIPELINE — 5 GITHUB ACTIONS WORKFLOWS



RESULTS & OUTCOMES

360°
Full NHI visibility across
GitHub + Azure + SSL

<2 min
End-to-end scan to
report

R²>0.89
30-day risk forecast
accuracy

0 manual
Zero manual credential
audits

- Isolation Forest caught **3 dormant PATs** (180+ days) missed by rule-based checks.
- NHI Gate** blocks PRs with overly-scoped credentials before merge.
- Immutable JSON audit log** for SOC 2 Type II evidence.
- Forecast triggered **proactive rotation** 12 days before SLA breach.
- IEEE paper** published — 90 scan-run evaluation.

FUTURE WORK & ROADMAP

Mutable Orchestration Graph (MOG)
Dynamic DAG-based orchestration — rewire agents at runtime, self-healing workflows.
ACTIVELY IN DEVELOPMENT

Multi-Cloud Expansion
AWS IAM, GCP service accounts, HashiCorp Vault — unified cross-cloud risk model.
PLANNED

ARIMA / Prophet Forecasting
Replace Linear Regression for seasonal rotation patterns — paper limitation.
RESEARCH

GNN Risk Propagation
Heterogeneous graph: identity → repo → secret. Transitive risk scoring.
RESEARCH

Blue-Green Secret Rotation
Zero-downtime rotation across dependent services with health-check validation.
PLANNED

AICPA Supplemental Criteria
Propose NHI-specific criteria for SOC 2 TSC — machine-verifiable audit evidence.
PROPOSED

TECHNOLOGY STACK

BACKEND — 6,118 LINES PYTHON

Python 3.11

LangChain

GPT-4o

scikit-learn

Flask

OPA / Rego

FRONTEND — 3,562 LINES TYPESCRIPT

React 18

TypeScript

Vite

Recharts

Tailwind CSS

CLOUD / DEVOPS

GitHub Actions

Azure SDK

Azure Key Vault

Azure Monitor

OpenSSL

"Shift-left security" — *governance checks at PR time, not post-breach.*

TEAM & GUIDE DETAILS

CM

Prof. Chethana Murthy
Internal Guide · Assistant Professor
Dept. of CSE · RV College of Engineering, Bengaluru

UM

Umang Mishra
Developer — Full Stack · ML · DevSecOps
USN: 1RV22CS220 · Dept. of CSE

TR

Tejeshwar Rao
External Guide · Manager — DevSecOps & Cloud
Honeywell · IA-DevSecOps Platform Engineering